

PHISHING AWARENESS SIMULATION REPORT

Controlled Security Assessment & Credential Harvesting Analysis

Assessment Type	Controlled Educational Simulation	Date	August 11, 2026
Framework Used	Zphisher v2.3.5 (htr-tech)	Environment	Isolated Loopback (127.0.0.1)
Target Template	Instagram Traditional Login Page	Port / Protocol	8080 / HTTP (Unencrypted)

1. EXECUTIVE SUMMARY & OBJECTIVES

This technical report documents a controlled **Phishing Awareness Simulation** executed in an isolated local loopback environment. The assessment was designed to analyze the technical operational flow of modern social engineering credential harvesting frameworks, evaluate victim interaction vectors, and formulate robust organizational countermeasures.

Primary Simulation Objectives:

- Demonstrate Attack Mechanics:** Analyze how social engineering tools deploy automated phishing templates to mimic legitimate authentication gateways.
- Identify Indicators of Compromise (IoCs):** Detail visual and technical anomalies, such as plain HTTP transportation, non-standard port hosting (: 8080), and local file-system credential logging.
- Develop Remediation Framework:** Establish actionable technical controls and security awareness training strategies to prevent credential theft.

2. PROJECT SCOPE

To ensure strict compliance with legal, ethical, and operational guidelines, the assessment boundaries were defined as follows:

In-Scope Activity	Out-of-Scope Activity
Localhost execution bound exclusively to loopback interface (127 . 0 . 0 . 1).	Production networks, external subnets, or WAN environments.
Mock credential submission using non-real test data (e.g., test account identifiers).	Targeting real users, employees, or harvesting legitimate production credentials.
Inspection of server logs (auth/ip.txt, auth/usernames.dat).	Active email delivery, domain spoofing, or unauthorized network transmission.

3. TOOLS & OPERATIONAL ENVIRONMENT

Tool / Component	Version / Type	Role & Function
Kali Linux	Debian-based OS	Core penetration testing platform hosting simulation scripts.

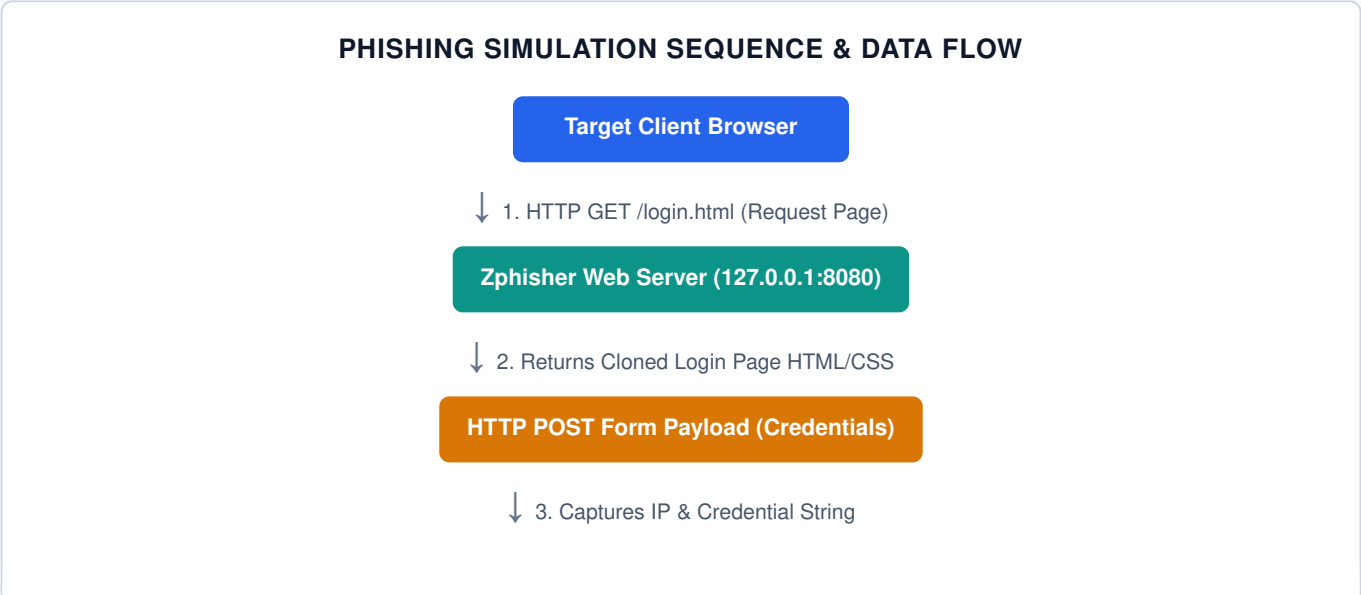
Tool / Component	Version / Type	Role & Function
Zphisher Framework	v2.3.5 (htr-tech)	Automated phishing generator used to host template assets.
Local Web Server	PHP / Cloudflare / Port 8080	Serves mock Instagram login template locally at <code>http://127.0.0.1:8080</code> .
Web Browser	Standard Chromium/Firefox	Simulates victim interaction and credential submission.
Log Store	Local Flat Files	Captures victim IP logs (<code>ip.txt</code>) and credentials (<code>usernames.dat</code>).

4. EXECUTION TIMELINE

Phase 1: Day 1	Environment Setup	Configured Kali Linux environment, initialized Zphisher v2.3.5, and bound server engine to local loopback <code>127.0.0.1:8080</code> .
Phase 2: Day 2	Attack Simulation	Deployed cloned Instagram login portal. Simulated victim access and form submission using test credentials (<code>absbabsa</code>).
Phase 3: Day 3	Data Capture & Audit	Audited server terminal outputs. Confirmed IP address logging in <code>auth/ip.txt</code> and credential extraction in <code>auth/usernames.dat</code> .
Phase 4: Day 4–5	Analysis & Reporting	Synthesized assessment findings, constructed network data flow diagrams, and defined organizational defensive controls.

5. ARCHITECTURE & DATA FLOW DIAGRAM

The diagram below illustrates the communication sequence between the target browser, the local phishing engine, and the server-side credential capture modules.



6. DEFENSIVE MITIGATION STRATEGIES

To protect enterprise assets against social engineering attacks modeled in this simulation, organizations should implement the following multi-layered controls:

- **FIDO2 / WebAuthn Hardware Keys:** Implement domain-bound Multi-Factor Authentication (MFA). Hardware tokens check the browser's domain origin, preventing users from authenticating against illegitimate hosts even if credentials are submitted.
- **URL & Certificate Inspection:** Educate users to verify the address bar for legitimate domain names (e.g., `instagram.com` vs. `127.0.0.1`) and ensure valid SSL/TLS certificates are present.
- **DNS Filtering & Web Reputation:** Deploy threat intelligence feeds and DNS filtering to automatically block access to newly registered domains and known phishing infrastructure.
- **Endpoint Detection & Response (EDR):** Utilize EDR tools to detect unauthorized web server execution or credential harvesting tools operating on internal hosts.